

Attachment A – Judiciary Identity, Authentication, and Access Management Requirements

Judiciary applications that require public access should integrate with a federated Identity and Access Management (IAM) / Identity Provider (IdP) vendor to provide secure authentication and identity services. This approach supports capabilities such as single sign-on (SSO), strong authentication with phishing-resistant MFA options, centralized identity management, and compliance with federal identity and security standards.

The Judiciary is currently using **Login.gov**, a Credential Service Provider (CSP), to serve as the identity provider for public facing applications, including JMS-eJuror, which is classified as a Medium to High data classification system. Leveraging Login.gov enables secure public user authentication while supporting required security, operational, and performance standards in alignment with TSIO guidance.

Additional implementation guidance and requirements are documented in the TSIO MFA Public Access Requirements documentation (reference link provided), which outlines the recommended approach for enabling secure authentication for public-facing Judiciary applications.

Internal Judiciary applications used by organizational users (judges, court staff, and AO personnel) should integrate with an enterprise Identity and Access Management (IAM) / Identity Provider (IdP) platform for authentication and identity management. This approach enables centralized Single Sign-On (SSO), Multi-Factor Authentication (MFA), and identity governance capabilities aligned with enterprise security practices and federal identity standards. It also supports standards-based federation protocols such as SAML 2.0, OpenID Connect (OIDC), and OAuth 2.0, enabling secure and consistent access across internal systems.

Currently, the Judiciary leverages Azure AD (Microsoft Entra ID) as part of its enterprise identity infrastructure to support authentication and access management for organizational users, providing centralized identity services and secure access to internal applications.

Based on the Judiciary Information Security Framework (JISF) and the NIST Digital Identity Guidelines, the requirement to support standards-based single sign-on (SSO) and identity federation protocols is supported through the following controls and guidelines:

1. Is Identity Proofing and MFA Mandatory?

- **Identity Proofing (IA-12):** This is mandatory for all Judiciary information systems categorized as Moderate (M) or High (H). It is considered optional (Opt) for systems categorized as Low (L). For High categorization systems, the validation of identity evidence must be conducted in person before a designated registration authority.

- MFA (IA-02): Multi-factor authentication is mandatory for Judiciary organizational users across all system impact levels (High, Moderate, and Low). Specifically:
 - MFA is required for access to privileged accounts.
 - MFA is required for access to non-privileged accounts.
- AAL2 Requirements: Agencies must select a minimum of Authenticator Assurance Level 2 (AAL2), which requires MFA, whenever Personally Identifiable Information (PII) or other personal information is made available online.
- System Security Categorization: Perform a security categorization (RA-02) to determine if the application is Low, Moderate, or High impact.
 - If the application is Moderate or High, identity proofing (IA-12) is mandatory.
- Presence of Sensitive Data (PII): If the application processes, stores, or transmits PII or personal information online, it must use at least AAL2.
 - AAL2 requires the use of two distinct authentication factors (MFA).

The requirement to comply with the NIST Digital Identity Guidelines has been established in this SOO. The citations and links below are provided to support vendor review of the referenced standards.

- NIST SP 800-63C-4 (Digital Identity Guidelines: Federation and Assertions):
 - Link: <https://doi.org/10.6028/NIST.SP.800-63c-4>.
- NIST SP 800-63B-4 (Authentication and Authenticator Management):
 - Section 7.1.2: Access Tokens (OAuth).
 - Link: <https://doi.org/10.6028/NIST.SP.800-63b-4>.
 - Link: <https://doi.org/10.6028/NIST.SP.800-63-4>.

DRAFT